

Vulnerability Audit and Assessment - Baseline Analysis and Plan

After evaluating the demo website "demo.testfire.net," a vulnerable testing platform, I identified a range of security issues that could expose a real business to considerable cyber risk. This document outlines a baseline analysis that highlights these issues, relevant security standards, tools to be used, and a mitigation roadmap. The goal is to inform the business of potential weaknesses and suggest a foundation for detailed scans and penetration testing later in the process.

Identified Security Challenges

Based on preliminary manual investigation, the following vulnerabilities and concerns were identified:

- **Lack of HTTPS:** The site uses HTTP instead of HTTPS, making data interception easy.
 - **SQL Injection:** User input was not sanitised, enabling possible SQL injection.
 - **Brute Force:** Login forms accept repeated attempts without rate limiting or account lockout.
 - **XSS Vulnerability:** Malicious scripts can be injected via input fields (search bar and contact form)
 - **Session Management:** After logout, users can access data using the browser back button, indicating poor session control.
 - **Lack of CAPTCHA or MFA:** No second-level authentication was found, increasing the likelihood of credential stuffing.
-

Relevant Standards

- **General Data Protection Regulation (GDPR):** Applicable as the site could handle personal data. Unsecured transmissions and poor session controls would violate GDPR Article 5(1)(f) (ICO, 2024).
 - **OWASP Top 10:** The issues align with critical risks listed by OWASP, such as injection, broken authentication, and insufficient logging and monitoring (OWASP, 2023).
-

Tools to be Used and Justification

Tools	Purpose	Justification
Nmap	Network mapping and open ports detection	To understand attack surface and fingerprint hosts.
Nikto	Web server vulnerability scanner	Useful for detecting insecure HTTP headers and outdated software.
OWASP ZAP	Dynamic vulnerability testing	Supports automated discovery of XSS, SQLi, and session issues.
Burp Suite	Manual and automated web vulnerability testing	Advanced analysis of user input validation and session management flaws.
WHOIS/DIG	DNS information and domain ownership	To identify ownership and email-related records like MX and SPF.
Traceroute	Network hops identification	Helps identify latency or bottlenecks that might reveal network weakness.

All tools selected are open-source or free to use and widely accepted in the industry.

Methodology

- **Remote and Non-Invasive:** Tools will be run from a Kali Linux virtual machine set up on VMware.
 - **Automated and Manual:** Initial findings will be automated, followed by targeted manual validation.
 - **Ethical and Responsible:** Only non-destructive scans are carried out on demo/test sites.
-

Assumptions and Limitations

- The site is intended to be vulnerable; actual production systems might behave differently.
 - Scan accuracy may vary based on the response and configuration of the web server.
 - DNS and WHOIS records may be protected using services like Cloudflare or identity masking.
 - Testing is limited to surface-level vulnerabilities due to scope boundaries.
-

Proposed Next Steps (Planning Phase)

The following stages will be undertaken in a logical sequence to ensure a thorough and organised assessment process:

1. Conduct full scans using the listed tools, document findings.
2. Perform manual verification of automated scan results.
3. Map vulnerabilities against OWASP and GDPR compliance.
4. Prioritise findings and prepare the Executive Summary (Assessment 2).

This structured approach promotes clarity, consistency and effective risk management throughout the evaluation process.

Summary and Recommendations

The demo website, although purposely vulnerable, mirrors many real-world issues still prevalent in production systems. Addressing the identified weaknesses would reduce the attack surface significantly. Key mitigation actions include:

- Enabling HTTPS to secure data in transit.
- Implementing prepared statements to prevent SQL injection.
- Rate-limiting login attempts and enabling account lockouts.
- Using secure session handling with token invalidation on logout.
- Enabling CAPTCHA and multi-factor authentication.

These recommendations not only strengthen the technical security posture but also enhance compliance with international standards.

References:

ICO (2024) *Guide to the General Data Protection Regulation (GDPR)*. [Online] Available at: <https://ico.org.uk/for-organisations/guide-to-data-protection/> [Accessed 16 May 2025].

OWASP (2023) *OWASP Top Ten Web Application Security Risks*. [Online] Available at: <https://owasp.org/www-project-top-ten/> [Accessed 16 May 2025].

Nmap (2024) *Network Mapper Tool*. [Online] Available at: <https://nmap.org/> [Accessed 16 May 2025].

OWASP ZAP (2024) *Zed Attack Proxy*. [Online] Available at: <https://www.zaproxy.org/> [Accessed 16 May 2025].

Burp Suite Community Edition (2024) *PortSwigger Web Security*. [Online] Available at: <https://portswigger.net/burp> [Accessed 16 May 2025].

WHOIS (2024) *Whois Lookup Tool*. [Online] Available at: <https://whois.domaintools.com/> [Accessed 16 May 2025].